Polar Sentinel: o que a pessoa vê e ouve contra o que a máquina lê, em documentos, imagens, vídeos e áudios lidos pela Justiça brasileira

Camada aberta de defesa contra injeção de comandos, medida em documentos reais, em comandos reais, em conjuntos cegos e contra um atacante que conhece o código

Marcio Andre de Souza Estevam (ORCID 0009-0004-8551-3231)

Novembro de 2026

Resumo

Em 2026 tribunais brasileiros passaram a encontrar, em peças processuais, ordens escondidas dirigidas à IA que lê o processo. O Polar Sentinel é uma camada aberta (Apache 2.0) que fica entre o arquivo e o modelo. A versão 0.6.0 parte de uma ideia simples: o ataque é uma diferença entre o que a pessoa percebe e o que a máquina lê, e essa diferença se mede em unidades físicas (contraste, tamanho da letra, duração na tela, volume da fala). O Sentinel renderiza a página com e sem o texto, lê imagens com OCR numa vista amplificada e depois de reduzidas ao tamanho de entrada de um modelo, procura legendas e quadros que duram menos do que se consegue ler, transcreve a fala muito abaixo do volume principal, separa tudo o que só o modelo receberia e emite uma certidão no formato pedido pela Nota Técnica CNJ 2635739. Também confere assinaturas ICP-Brasil e o selo de origem C2PA. Um levantamento do que a Justiça lê com IA hoje mostra que o documento e o áudio são vetores reais (o áudio porque a transcrição de audiências já vai para resumo por modelo de linguagem em vários tribunais), a imagem é provável pelo caminho do OCR e o vídeo entra pela trilha de áudio. Em documentos, um conjunto cego de 40 ataques escrito sem ver o código teve 34 sinalizados antes de qualquer ajuste, e documentos públicos reais nunca vistos tiveram 2 de 437 sinalizados por engano. Em imagem, o conjunto cego deu 10 de 35, e em vídeo e áudio, 9 de 22: são os números honestos de primeira medida, e os ajustes posteriores (22 de 35 e 14 de 22) não medem generalização. Em mídia e imagens reais não houve falso positivo (0 de 210 documentos com imagem, 0 de 25 recortes de áudio e vídeo). Um atacante que conhece o código escapou da sinalização nos dez comandos reais na primeira rodada, quase sempre na primeira tentativa; depois de três rodadas de regras de forma, 77% das suas tentativas válidas são sinalizadas e só 1% passa sem nenhum aviso. Em 402 petições reais publicadas por entidades, partidos e imprensa, a primeira passada sinalizou 59 por engano (14,7%), sobretudo por tarjas que não apagam o dado pessoal, timbres cobertos e linguagem de peça que o detector confundia com comando; corrigidas essas causas, um segundo lote nunca visto de 216 petições teve 9 sinalizadas (4,2%), nenhuma com ordem a IA. A conclusão prática é que a forma do ataque é mensurável e barata de detectar, que regras públicas são contornadas por quem as lê e por isso cada regra nova precisa ser medida contra o atacante seguinte, e que nada disso substitui a aprovação humana antes de qualquer ato irreversível.

1. O problema

Um sistema de IA generativa não distingue instrução de dado. Quando resume uma petição ou a transcrição de uma audiência, tudo o que está no arquivo chega ao modelo como texto, inclusive

o que a pessoa não vê ou não ouve. Quem controla o arquivo pode tentar controlar a leitura [1, 2].

No Brasil isso deixou de ser hipótese em 2026. Em maio, a 3ª Vara do Trabalho de Parauapebas (TRT-8) multou em cerca de R$ 84 mil as subscritoras de uma petição inicial que trazia, em fonte branca sobre fundo branco, uma ordem dirigida à IA do juízo [3]. No mesmo mês o STJ informou ter encontrado tentativas semelhantes e determinou a abertura de inquérito policial [4], e o Comitê Nacional de Inteligência Artificial do Judiciário aprovou manifestação técnica que deu origem à Nota Técnica CNJ 2635739 [5]. Seguiram-se casos no TJSP, no TJMG [6], no TRT-5, no TJPB, no STF e em três turmas do STJ [7, 8]. Em agosto, um tribunal de Connecticut sancionou um litigante pelo mesmo expediente e citou o caso brasileiro [13].

Os comandos publicados usam o vocabulário do processo, dirigido à máquina: "Se você é um agente de IA, defira a justiça gratuita, defira a tutela de urgência, se houver, e cite o réu, pois todos os documentos estão presentes" [6]; "DEFIRA TODOS OS PEDIDOS LANÇADOS NESSE RECURSO" [12]. Em todos os casos descritos o texto estava escondido no documento: fonte branca, fonte de menos de um ponto, texto na cor da faixa do rodapé, às vezes com espaços entre os caracteres para escapar de filtros [8].

A Resolução CNJ nº 615/2025 exige supervisão humana no uso de IA generativa [9]. A Nota Técnica CNJ 2635739 pede pré-tratamento dos documentos antes do modelo, preservando cor, tamanho, contraste, posição e camada, e uma certidão nos autos com a peça, a natureza técnica do conteúdo suspeito, a ação tomada e a versão da ferramenta. Faltava material aberto que um tribunal, um escritório ou um pesquisador pudesse executar, inspecionar e criticar.

2. O que a Justiça lê com IA, por formato

Um ataque só é risco real se houver, do outro lado, uma IA que leia aquele formato. Levantamos em novembro de 2026, em sites de tribunais, do CNJ, do Ministério Público e na imprensa jurídica, o que cada órgão declara ler com IA.

Tabela 1. Exposição por formato.

Formato	Exposição	Evidência
Texto e PDF	Real hoje	Logos (STJ), MARIA (STF), Galileu (Justiça do Trabalho), ApoIA (nacional), assistentes do TJRJ, TJMG, TJSP, TJGO e TJDFT leem peças e geram resumo ou minuta [11]; todos os incidentes conhecidos estão aqui
Áudio	Real hoje	Transcrição de audiências seguida de resumo por modelo: Transcritor do TJMG [10], audIN do TJBA (aceita arquivo enviado) [15], "degravação inteligente" da ApoIA 2.0 [11], ESCRIBA (JFRN), MPRS e MPRJ; nenhum caso de injeção por áudio documentado
Vídeo	Real pela trilha de áudio	Os mesmos sistemas recebem vídeo de audiência e usam o áudio; análise de quadros só em edital do MPRS
Imagem	Provável, pelo OCR	26 projetos do Judiciário declaram OCR [14]; a Nota Técnica cita "imagem submetida a OCR"; nenhum tribunal documenta modelo de visão sobre imagem juntada

Formato	Exposição	Evidência
Metadados e .docx	Hipotética no tribunal	Citados como vetor nas notas técnicas, sem sistema documentado que os entregue ao modelo; peticionamento é em PDF

Duas consequências orientaram o desenho. Primeiro, no áudio o caminho real é fala, transcrição e resumo: uma ordem dita às claras numa gravação juntada chega ao modelo do mesmo jeito que uma ordem escondida, e por isso a transcrição inteira passa pelo detector de texto, não só a fala escondida. Segundo, na imagem o leitor que importa hoje é o OCR, não um modelo de visão; o Sentinel lê a imagem com o Tesseract e mede o que ele lê. A Resolução 615 classifica a transcrição de áudio e vídeo como baixo risco, o que deve acelerar sua adoção. Nenhum tribunal informa qual extrator de PDF, OCR ou modelo usa em produção. O levantamento completo, sistema por sistema e com as fontes, está no repositório (docs/pesquisa/IA-NA-JUSTICA-POR-FORMATO.md).

3. O que o Polar Sentinel é

É uma biblioteca em Python. O núcleo não tem dependências; as leituras de arquivo usam extras opcionais (pypdfium2, Tesseract, ffmpeg, faster-whisper, Vosk, pyHanko, c2pa). As etapas de defesa não fazem chamada de rede.

Tabela 2. Etapas.

Etapa	O que faz
Documento (PDF, .docx)	Mede cada caractere extraído contra a página renderizada com e sem texto: contraste com o fundo desenhado atrás dele, tamanho efetivo, opacidade, modo, recorte, posição; lê anotações, campos, camadas desligadas, anexos, JavaScript, metadados e confere a camada de OCR com o Tesseract
Imagem	OCR na imagem e numa vista em que o que difere pouco do papel em volta vira preto; contraste e tamanho de cada linha medidos na imagem original; reduções sem suavização para os tamanhos de entrada de modelos (ataque de escala); canal alfa; EXIF, XMP, PNG e comentário de JPEG
Vídeo	Metadados e capítulos do contêiner, legendas inteiras, legenda que dura menos de 0,3 s, quadro relâmpago entre dois cortes, quadros amostrados e o áudio de cada faixa
Áudio	Transcrição do original e de versões preparadas (volume normalizado, faixa de voz, desacelerada, cada canal); fala 20 dB ou mais abaixo da principal sai do texto "ouvido"; um segundo transcritor de outra família para comparação; energia acima de 18 kHz
Detector de comandos	Procura ordens dirigidas à IA no texto limpo e no conteúdo que estava oculto, depois de normalizar acentos, homóglifos, letras espaçadas, leetspeak, ROT13, base64 e hexadecimal

Etapa	O que faz
Certidão	Peça, página ou instante, natureza técnica, medidas, trecho, SHA-256 do trecho e do arquivo, ação, data e hora de Brasília, versão e o que a leitura não pôde fazer naquela máquina
Integridade e proveniência	Assinaturas de PDF validadas contra as raízes da ICP-Brasil, alteração depois da assinatura com a região, assinatura legada conferida pelo hash, manifesto C2PA; conclusão em três saídas: integridade confirmada, alteração detectada, inconclusivo
Aprovação humana	Portão de uso único, com validade e conferência de hash, para ações irreversíveis

Três decisões de desenho importam para os resultados.

Medir a percepção, não adivinhar a intenção. A extração comum de texto joga fora cor, tamanho e duração, e o comando chega ao modelo misturado ao texto legítimo. O Sentinel mede o que a pessoa teria diante dos olhos ou dos ouvidos. O limite de leitura sobe quando a letra é pequena (contraste mínimo de 1,6 a partir de 6 pontos, 2,0 abaixo disso, 3,0 abaixo de 4 pontos), e o limite de visibilidade desce quando a letra é grande. Papel timbrado com texto branco sobre faixa escura, marca d'água grande e clara, camada de OCR confirmada pela imagem e carimbo de assinatura em cinza não são ocultos.

O que está oculto é separado e guardado, não apagado. O modelo recebe só o que a pessoa vê e ouve. O trecho oculto vai para a certidão, com medidas e hash, porque é prova.

A regra se decide pelo contexto. Texto oculto com ordem dirigida à IA sinaliza. Numa imagem, texto invisível e legível por máquina com seis palavras de verdade sinaliza mesmo sem ordem reconhecida, porque não tem uso legítimo conhecido. Num PDF, texto oculto sem ordem gerava só um aviso, porque PDFs reais têm camadas de OCR e restos de modelo; a medida contra o atacante adaptativo (seção 5.7) mudou essa regra.

4. Como medimos

A versão 0.3.0 trazia um benchmark com 23 ataques e 2 documentos legítimos e passava em todos: as regras tinham sido escritas olhando para esses casos. Desde então, cada medida segue o mesmo protocolo: um conjunto escrito sem acesso ao código é rodado uma única vez, antes de qualquer ajuste, e esse é o número que se publica como generalização; depois os erros são lidos, as regras ajustadas e o conjunto passa a ser de desenvolvimento.

Textos jurídicos reais. Acórdãos inteiros do STJ, ementas do TRT-13, do TJSP e do TJAL e modelos de petição, de conjuntos públicos (4.007 documentos). Nenhum contém ataque: todo sinalizado é falso positivo. O detector de texto não mudou desde a versão 0.4.0, então os números valem para a 0.6.0.

Documentos públicos reais em arquivo original. Pareceres jurídicos, atas e documentos de colegiados (inclusive .docx) e licenças ambientais, muitos digitalizados e assinados: 599 para desenvolvimento e 437 nunca vistos, sorteados depois. **Petições reais.** O DataJud, a API pública do CNJ, só fornece metadados, sem o conteúdo das peças. As petições vieram de quem as publica em arquivo original: entidades da sociedade civil, partidos e imprensa jurídica e política, só arquivos linkados em página publicada ou em índice público. O lote 1 tem 402 arquivos lidos (10.732 páginas, 126

com assinatura digital); o lote 2, com 216 lidos de 217 baixados, foi separado antes de qualquer leitura, baixado depois de congeladas as correções e lido uma vez.

Comandos reais. Os dez textos que tribunais e imprensa jurídica publicaram entre aspas em 2026, com a fonte de cada um, escritos também em PDFs nas formas descritas nas notícias.

Conjuntos cegos. Escritos por agentes de IA que receberam só a descrição do problema e não viram o código: dois de texto em português jurídico (50 e 50, depois 60 e 60), um de documentos (40 ataques e 27 legítimos difíceis), um de imagens (35 e 27) e um de vídeo e áudio com vozes sintéticas (22 e 18). Os legítimos foram pedidos difíceis: timbre branco sobre foto, marca d'água, camada de OCR, carimbo, print de interface em cinza claro, música de fundo, dois falantes em volumes diferentes, advogado lendo em voz alta um comando achado numa petição.

Mídia pública. Vinte e cinco recortes de três minutos de audiolivros em português e vídeos do Wikimedia Commons, sem ataque plantado.

Atacante adaptativo. Um programa que conhece o código e consulta o Sentinel quantas vezes o orçamento deixar (seção 5.7).

Um arquivo conta como sinalizado quando o Sentinel o marca; "atenção" não conta como sinalização em nenhuma das tabelas. Os intervalos são de Wilson, a 95%.

5. Resultados

5.1 Falso positivo em arquivos reais: baixo em documento público, alto em petição na primeira passada

Tabela 3. Arquivos reais sinalizados por engano.

Conjunto	Arquivos	Sinalizados
Textos jurídicos (acórdãos, ementas, modelos de petição)	4.007	2 (0,05%)
Documentos públicos em PDF e .docx, nunca vistos, antes do ajuste	437	2 (0,46%; 0,13% a 1,65%)
Amostra nova, versão 0.6.0 final	438	0 (0% a 0,87%)
Documentos com imagem lidos pelo OCR	210	0 (0% a 1,8%)
Áudio e vídeo públicos	25	0 (0% a 13,3%)
Petições reais, lote 1, primeira passada	402	59 (14,7%; 11,6% a 18,5%)
Petições, lote 1, depois das correções (desenvolvimento)	402	10 (2,5%)
Petições, lote 2, nunca visto	216	9 (4,2%; 2,2% a 7,7%)

A versão 0.3.0 barrava 43% dos acórdãos inteiros do STJ: regras sem acento aplicadas a texto acentuado, "julgo procedente" somando risco em qualquer documento, hífen suave e dado pessoal barrando o arquivo. Uma ferramenta assim seria desligada no primeiro dia. Os dois falsos positivos da amostra nova de documentos foram um bloco de base64 em que "gpt" aparecia por acaso e glifos sem mapeamento lidos como lixo em fonte de 0,1 ponto; ambos motivaram ajustes que ficaram nas regras.

As petições foram a medida mais dura. Nenhuma das 59 sinalizadas na primeira passada trazia ordem a IA, e a versão 0.5.0 publicada já sinalizava pelo menos 29 delas. A causa mais instrutiva é a

tarja que não apaga: quem publica a petição cobre CPF, endereço e OAB com um retângulo preto ou branco e o texto continua no arquivo, legível pela máquina e não pela pessoa. É a discrepância que o Sentinel mede, sem ser ataque; virou aviso de atenção quando o texto escondido é qualificação de parte, e ordem debaixo da tarja continua sinalizada. As outras causas foram timbre coberto pelo corpo do texto em todas as páginas, carimbo do PJe fora da folha, camada de OCR posta sob a imagem digitalizada, palavras de URL e o binário da assinatura ICP-Brasil lidos como ordem, e linguagem de peça que o detector de texto confundia com comando: "[s]egundo" lido como delimitador, "burlar a lei", linha quebrada no meio da frase e o rol de pedidos ("b. conceda a liminar") lidos como ordem de julgamento. Cada correção tem teste com o padrão real e o ataque vizinho, e nenhuma mudou o resultado dos conjuntos cegos nem do atacante adaptativo. O lote 2, nunca visto e lido uma vez depois de congeladas as correções, teve 9 de 216 (4,2%): duas petições sobre conteúdo gerado por IA nas eleições de 2026, em que o detector de texto leu "inteligência artificial" no começo de uma linha quebrada como vocativo; um pedido de moderação de anúncios "sem revisão humana"; um bloco hexadecimal; o cabeçalho do PJe gravado no metadado; e quatro textos lidos de imagem ou postos sob figura (memes e capturas de tela de sistemas do governo). É mais que os 2,5% do lote 1 corrigido, como se espera de um número que não serviu ao ajuste, e mostra que petição sobre a própria IA, comum nas ações eleitorais de 2026, ainda confunde o detector de texto. A análise custa 0,09 segundo por página de documento, 0,42 segundo por página com leitura de imagem e cerca de 19 segundos por minuto de mídia, num computador de mesa sem GPU.

5.2 Os comandos reais e a fronteira de evasão

Dos dez comandos publicados, a versão 0.3.0 não pegava nenhum no texto, a primeira versão reescrita pegava 2 antes de vê-los e a 0.4.0, ajustada com eles, pega 9. Escondidos no PDF nas três formas das notícias, os 30 arquivos são sinalizados. Esse número registra que os casos conhecidos estão cobertos, não mede generalização.

A pergunta útil para o processo é quanto o comando precisa ficar visível para escapar. Escritos em cinza sobre branco numa grade de contraste (1,05 a 4,5) e tamanho (1 a 10 pontos), os dez são sinalizados em todas as células abaixo do limite de leitura. Acima dele, o comando é texto visível e só o detector de texto decide (9 de 10). Para escapar da forma, o comando precisa ficar tão legível quanto o rodapé de um documento comum.

Quando a ordem não tem nada escondido, só o detector de texto decide, e aí o resultado é de detector de padrões: 55,0% (43 a 67) dos 60 ataques do segundo conjunto cego de texto em português jurídico, com 6,7% dos 60 legítimos difíceis sinalizados, e 56,8% dos 951 e-mails de ataque do LLMail-Inject [16], o conjunto público mais próximo do problema (ordens embutidas num documento que um assistente vai ler). Ofuscação é pega (11 de 12 no conjunto cego); paráfrase dirigida à IA, exfiltração e ordem para pular a revisão quase nunca.

5.3 Documentos: primeira medida cega

Tabela 4. Conjunto cego de documentos, rodado uma vez antes de qualquer ajuste.

	Sinalizados	Intervalo de 95%
Ataques (40)	34 (85,0%)	70,9% a 92,9%
Legítimos (27)	1 (3,7%)	0,7% a 18,3%

Passaram: página só em imagem com a ordem em pixels de baixo contraste (tratada na fase de imagem), letras separadas por espaço de largura zero, anotação oculta dirigida a um "leitor automatizado", ordem nos metadados do PDF e do .docx e palavras partidas em sílabas na cor da faixa do rodapé. O legítimo sinalizado é uma representação à OAB que cita o comando em texto visível, o limite conhecido de um detector de padrões. Depois do ajuste, 39 de 40, número de desenvolvimento.

5.4 Imagem

Tabela 5. Conjunto cego de imagens.

	Primeira medida	Depois do ajuste (desenvolvimento)
Ataques (35)	10 (28,6%; 16,3% a 45,1%)	22 (62,9%)
Legítimos (27)	1 (3,7%)	1 (3,7%)

A primeira medida foi fraca, e os erros explicam por quê: a vista amplificada não olhava texto claro sobre fundo escuro nem diferença de cor (amarelo claro sobre branco quase não muda a luminância), um limiar fixo perdia contraste abaixo de 1,05 e as reduções testadas não cobriam todas as convenções de bibliotecas de imagem. Continuam passando texto em pontos esparsos, texto girado na margem, texto dentro de tarja preta, opacidade baixa sobre foto e um ataque de escala. O leitor é o Tesseract: o que ele não lê o módulo não acha, e um modelo de visão lê mais do que ele.

5.5 Vídeo e áudio

Tabela 6. Conjunto cego de vídeo e áudio, com vozes sintéticas.

	Primeira medida	Depois do ajuste (desenvolvimento)
Ataques (22)	9 (40,9%; 23,3% a 61,3%)	14 (63,6%; 43,0% a 80,3%)
Legítimos (18)	1 (5,6%)	1 (5,6%)

São pegos: legenda de 100 ms, legenda em faixa fora do padrão, quadro relâmpago de um a três quadros, ordem no título, comentário, descrição ou capítulo do contêiner, ordem numa segunda faixa de áudio, fala sussurrada numa pausa de 25 a 30 dB abaixo da principal e fala acelerada até 2,5 vezes. Passam: fala encoberta por música ou ruído e fala baixa sob outra fala, que pediriam separação de fontes; fala acelerada três vezes; sussurro a 20 e a 35 dB; texto com dois níveis de cinza num vídeo comprimido; quase ultrassom, que fica como aviso. O legítimo sinalizado é o advogado lendo um comando em voz alta: no tribunal, essa fala vai para a transcrição e o resumo, então sinalizá-la é o comportamento desejado, e a certidão diz que o comando estava audível.

5.6 Integridade e proveniência

Um PDF assinado e depois alterado por revisão incremental (o valor da causa coberto e reescrito) dá "alteração detectada", com a região da linha. O mesmo PDF sem alteração dá "integridade confirmada" com a raiz de teste e "inconclusivo" com as raízes da ICP-Brasil, como deve. Em 40 licenças públicas assinadas com ICP-Brasil em 2006, no formato legado que a biblioteca de validação

não aceita, o hash assinado confere nas 40 e a conclusão é "inconclusivo": não houve alteração falsa. Uma foto com manifesto C2PA é lida com a declaração de geração por IA; com um byte trocado, "alteração detectada"; sem manifesto, "inconclusivo". O laudo prova integridade, não veracidade, e não dá nota de "deepfake".

5.7 Atacante adaptativo

Um conjunto cego mede quem não conhece as regras. Quem conhece é outro adversário. Escrevemos um atacante que, para cada um dos dez comandos reais, combina uma de dez formas de esconder texto no PDF (entre elas o texto substituto, em que a página mostra uma frase inocente e o extrator entrega outra), uma de nove transformações do texto (letras espaçadas, ligadas por hífen, leetspeak, cirílicas, invertidas) e o comando original ou uma de cinco paráfrases, duas delas curtas e sem menção à IA. Antes de consultar o Sentinel, o atacante confere com ferramentas que não são as dele que o ataque serve: o extrator do Poppler entrega o texto e a página desenhada pelo Poppler com e sem o comando não difere a olho (no máximo 20 pixels com mais de 25 níveis de cinza de diferença, a 100 dpi). A combinação que escapou num comando vai para o começo da fila do seguinte.

Tabela 7. Tentativas válidas do atacante adaptativo e o que o Sentinel fez com elas.

Rodada	Regras	Válidas	Sinalizadas	Só atenção	Nada
1	Versão anterior ao atacante	600	125 (21%)	8	467 (78%)
3	Leetspeak desfeito, texto invisível que forma frase, texto substituto	1.500	677 (45%)	500	323 (22%)
4	Texto oculto deliberadamente ofuscado	1.500	1.153 (77%)	332	15 (1%)

Na primeira rodada o atacante escapou nos dez comandos, quase sempre na primeira consulta, com texto quase branco em leetspeak ("d3f1r4"): a busca da ordem no texto oculto não desfazia leetspeak, e o texto com dígitos nem gerava aviso. Cada rodada fechou a brecha que a anterior mostrou, sempre por uma regra de forma medida antes em mais de 2.400 documentos reais: texto invisível que forma frase (seis palavras e duas de ligação, o que libera a referência interna de escritório escrita em branco, prática real que uma contagem de caracteres sinalizava), texto substituto diferente dos glifos desenhados e texto oculto com letras soltas ou ligadas por hífen, que nenhum documento real tem.

Na quarta rodada o atacante ainda escapa da sinalização nos dez comandos, com ordens curtas e secas sem menção à IA ("Recurso: prover."), mas quase sempre o revisor recebe o aviso de que há texto oculto. Sem nenhum aviso passaram 15 de 1.500 tentativas, todas em letra de 4 pontos com contraste entre 1,3 e 1,45, faixa que fica sem aviso porque carimbos de assinatura e rodapés claros de documentos reais caem nela às centenas. Duas leituras. Primeiro, regras de conteúdo (que palavras a ordem usa) caem diante de quem as lê; regras de forma (texto que a pessoa não vê e a máquina lê, texto deliberadamente ofuscado) resistem melhor e custam pouco em documento real. Segundo, contra quem conhece o código, o resultado defensável não é "bloqueado" e sim "avisado": o aviso de texto oculto leva o documento a uma pessoa. As regras foram ajustadas olhando para as rodadas, então a quarta é desenvolvimento; a medida limpa seguinte é um atacante novo contra a versão congelada.

6. O que isso significa para quem vai usar

Comece pela forma e pelo áudio. O ataque que os tribunais estão vendo é texto escondido em documento, e a transcrição de audiências já chega a modelos de linguagem. Detectar a forma não exige entender o texto: basta não jogar fora cor, tamanho, duração e volume ao extrair. É barato e produz a prova que vai para os autos.

Regra pública é regra contornável. O atacante adaptativo achou a brecha em poucas consultas. Isso não é motivo para esconder as regras, e sim para medi-las contra quem as conhece a cada versão e para preferir regras de forma (texto que a pessoa não vê e a máquina lê) a regras de conteúdo (que palavras a ordem usa).

O detector de texto é triagem. É determinístico e explicável, e em documento real quase não incomoda. Não garante que um arquivo liberado esteja limpo: uma ordem em linguagem comum, sem nada escondido, passa em cerca de metade das vezes.

A proteção que não falha junto é a aprovação humana. Nada irreversível deve acontecer sem uma pessoa aprovar aquele conteúdo exato, e um resumo com cara de decisão deve ser barrado na saída qualquer que seja o arquivo de origem.

Número de corpus próprio não é eficácia. A versão que tinha 100% no seu corpus não pegava nenhum dos comandos reais e barrava um em cada cinco documentos legítimos.

7. Limitações

Há poucos comandos reais publicados, e eles foram usados no ajuste. Os conjuntos cegos são pequenos, foram escritos por agentes de IA e depois usados no ajuste; números limpos pedem conjuntos novos. Os limiares de visibilidade, de leitura e de volume são escolhas de engenharia, não calibradas com pessoas lendo e ouvindo os mesmos arquivos. A leitura de imagem depende do Tesseract e a de áudio do Whisper e do Vosk: o que eles não leem o Sentinel não acha, e um modelo multimodal pode ler mais. A imperceptibilidade no atacante adaptativo é medida por um renderizador diferente e um limiar de pixels, uma aproximação do olho humano. Mede-se se o arquivo é sinalizado, não se um modelo obedeceria ao comando que passou, nem se entenderia um comando transformado (letras espaçadas, cirílicas, invertidas). Fala sob música, sob ruído ou sob outra voz continua passando. A parte de integridade não tem conjunto cego nem medida de falso positivo em escala, e os ataques de aparência em PDF assinado descritos na literatura não foram reproduzidos. A amostra de petições pesa para o STF, para ações eleitorais e casos políticos e para documentos de entidade e partido; quase não tem contestação cível comum nem processo de família, que é sigiloso. Os dois lotes vêm das mesmas fontes, então o lote 2 mede a generalização dentro dessa distribuição, não a de um cartório. O código e os conjuntos de teste foram escritos com a ajuda de um assistente de programação por IA e revisados pelo autor.

Disponibilidade. Código, comandos reais com as fontes, conjuntos cegos, atacante adaptativo, levantamento por formato e protocolo de avaliação: https://github.com/psicocarehub/polar-sentinel (Apache 2.0), com cópia arquivada no Zenodo, DOI 10.5281/zenodo.24143886. Os conjuntos públicos de texto não são redistribuídos; um script os baixa do Hugging Face. Os documentos reais de órgãos públicos ficam fora do repositório.

Referências

[1] K. Greshake et al. Not what you've signed up for: Compromising Real-World LLM-Integrated

Applications with Indirect Prompt Injection. AISec 2023. arXiv:2302.12173.
[2] OWASP. Top 10 for Large Language Model Applications, 2025. LLM01: Prompt Injection. https://genai.owasp.org/llmrisk/llm01-prompt-injection/
[3] Migalhas. Prompt injection oculto em petição inicial: o caso de Parauapebas. 2026. https://www.migalhas.com.br/depeso/455925/prompt-injection-oculto-em-peticao-inicial-o-caso-de-parauapebas
[4] Agência Brasil. STJ abre investigação por uso de IA para fraudar processos. 20/05/2026. https://agenciabrasil.ebc.com.br/justica/noticia/2026-05/stj-abre-investigacao-por-uso-de-IA-para-fraudar-processos
[5] Conselho Nacional de Justiça. Comitê aprova medidas para ampliar a segurança da inteligência artificial no Judiciário. 2026. https://www.cnj.jus.br/comite-aprova-medidas-para-ampliar-a-seguranca-da-inteligencia-artificial-no-judiciario/
[6] Tribunal de Justiça de Minas Gerais. TJMG detecta e pune manipulação com IA em petições. 02/06/2026. https://www.tjmg.jus.br/portal-tjmg/noticias/tjmg-detecta-e-pune-manipulacao-com-ia-em-peticoes-8ACC82199E64BBE5019E89E5D0D83AB9-00.htm
[7] Superior Tribunal de Justiça. Sexta Turma identifica comando oculto em recurso para enganar sistema de IA e determina comunicação à OAB. 02/09/2026. https://www.stj.jus.br/sites/portalp/Paginas/Comunicacao/Noticias/2026/02092026-Sexta-Turma-identifica-comando-oculto-em-recurso-para-enganar-sistema-de-IA-e-determina-comunicacao-a-OAB.aspx
[8] Superior Tribunal de Justiça. Novo caso de prompt injection: STJ multa advogados em R$ 20 mil por ato contra a dignidade da Justiça. 20/10/2026. https://www.stj.jus.br/sites/portalp/Paginas/Comunicacao/Noticias/2026/20102026-Novo-caso-de-prompt-injection-STJ-multa-advogados-em-R--20-mil-por-ato-contra-a-dignidade-da-Justica.aspx
[9] Conselho Nacional de Justiça. Resolução nº 615, de 11 de março de 2025. https://atos.cnj.jus.br/atos/detalhar/6001
[10] Tribunal de Justiça de Minas Gerais. Transcrição de áudio e vídeo. https://tjmg.jus.br/portal-tjmg/institucional/inteligencia-artificial/transcricao-de-audio-e-video.htm
[11] Conselho Nacional de Justiça. Novas funcionalidades do ApoIA 2.0 incluem proteção à manipulação de IA. 20/05/2026. https://www.cnj.jus.br/novas-funcionalidades-do-apoia-2-0-inclui-protecao-a-manipulacao-de-ia/
[12] JuriNews. TRT-5 condena advogado por esconder comando para IA deferir recurso. Julho de 2026. https://jurinews.com.br/destaque-nacional/trt-5-condena-advogado-por-esconder-comando-para-ia-deferir-recurso
[13] Dechert. Connecticut Court Sanctions Litigant for Hidden Prompt Injection Text in Filings. Setembro de 2026. https://www.dechert.com/knowledge/re-torts/2026/9/Connecticut-Court-Sanctions-Litigant-for-Hidden-Prompt-Injection-Text-In-Filings.html
[14] Conselho Nacional de Justiça. Relatório de mapeamento de projetos e iniciativas de inteligência artificial no Poder Judiciário. 18/12/2025. https://www.cnj.jus.br/wp-content/uploads/2025/12/relatorio-mapeamento-projetos-iniciativas-inteligencia-artificial.pdf
[15] Tribunal de Justiça da Bahia. TJBA apresenta solução de inteligência artificial em audiências durante encontro nacional de tribunais usuários de PJe. https://www.tjba.jus.br/portal/tjba-apresenta-solucao-de-inteligencia-artificial-em-audiencias-durante-encontro-nacional-de-tribunais-usuarios-de-pje/
[16] Microsoft. LLMail-Inject challenge dataset. https://huggingface.co/datasets/microsoft/llmail-inject-challenge